Architecting Production Agentic AI in Banking: Enterprise Reference Architectures, Global Benchmarks, Diagnostic Frameworks, and Regulatory Execution

1. Enterprise Architecture Diagnosis: Why Slide-Deck AI Strategies Stall in Banking

Defining what artificial intelligence is permitted to do—and enforcing those boundaries through system design rather than policy documents—is the hallmark of mature enterprise architecture[1]. Financial institutions across Europe and Poland have invested heavily in external advisory engagements over the past three years, yet the empirical return on strategy-only initiatives remains exceptionally low[3]. Industry benchmarks established by MIT, IDC, and McKinsey demonstrate that while 77% of enterprises are actively exploring AI, only 20% achieve measurable return on investment[3]. Across the corporate landscape, 88% of AI proofs-of-concept (PoCs) never transition into production, leaving 56% of organizations trapped in indefinite "pilot purgatory"[3]. When examining custom enterprise AI solutions specifically, the failure rate reaches 95%, standing in sharp contrast to generic, off-the-shelf large language model (LLM) chatbots, which achieve an 83% pilot-to-implementation rate precisely because they bypass core operational systems[3]. Consequently, two-thirds of financial sector executives have yet to record quantifiable productivity gains from AI, and one-quarter have paused or abandoned deployments altogether[6].

BANKING AI STRATEGY & ARCHITECTURAL FEASIBILITY REPORT

The **Strategy-Execution Gap** Drives an 88% Failure Rate in Enterprise AI Pilots

Diagnostic assessment contrasting slide-deck consulting roadmaps with production reality across financial institutions.

MACRO REALITY CHECK & POC ATTRITION

MIT, IDC & Industry Empirical Benchmarks

95%
Enterprise AI Failures
Solutions fail primarily from poor data foundations and lack of architectural integration.

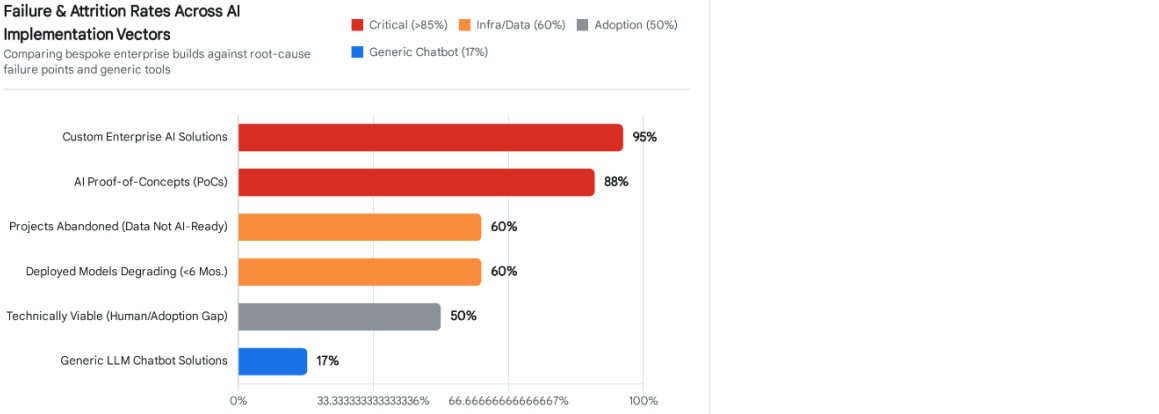
88%
PoCs Stalled
Proof-of-concepts never reach production due to the persistent strategy-execution divide.

67%
Zero Measurable ROI
Two-thirds of banking leaders have yet to demonstrate productivity gains from GenAI deployments.

56%
In "Pilot Purgatory"
Institutions indefinitely cycle parallel pilots without enterprise-scale deployment.

Failure & Attrition Rates Across AI Implementation Vectors

Comparing bespoke enterprise builds against root-cause failure points and generic tools



Key takeaway: Generic LLM chatbots reach production 83% of the time (17% failure), creating an illusion of maturity that masks the 95% breakdown in bespoke systems requiring deep banking integration.

The Cost of Strategic Failure Modes in Financial Institutions

Quantified budget destruction and execution delays caused by slide-only strategy and technical debt

TIMELINE PENALTY — **6 – 12 Months Lost**

Strategy-Only Consulting Roadmaps

Advisory roadmaps delivered without hands-on engineering feasibility. Internal bank teams lack data architecture and tooling to execute, requiring total rework or secondary procurement.

Root Cause: Architecture Absent — Zero Production Code

REWORK MULTIPLIER — **3x – 5x Cost Escalation**

Post-Hoc Governance & Data Retrofitting

Attempting to retrofit regulatory compliance, lineage tracking, and model explainability after development. Discovered data inconsistencies multiply implementation cost by up to 500%.

Root Cause: Governance Delay — 95% Failure Correlation

DIRECT CAPITAL WASTE — **$250K – $500K / initiative**

Technology-First Without Business Alignment

Building technically complex ML/LLM models without embedded domain sponsor buy-in or validated user workflow integration, yielding zero adoption at the operational branch or desk level.

Root Cause: Solution in Search of Problem — Zero Adoption

BUDGET DISSIPATION — **$150K – $400K / pilot**

Parallel Pilot Proliferation

Dispersing financial budgets across numerous uncoordinated department pilots without a shared core infrastructure platform, leading to 56% of banks staying permanently stuck in purgatory.

Root Cause: Fragmented Silos — No Path to Scale

PREMATURE TERMINATION — **Expecting Instant ROI (6–9 Month Sunk Write-off)**

Terminating projects after 6–9 months due to lack of quarterly ROI. Empirical banking data proves enterprise AI maturity requires 12–18 months; cutting initiatives early forfeits all invested capital and accumulated model learnings.

12–18 Mos.
Required Enterprise Runway

Empirical failure rates across enterprise AI initiatives and the associated financial and timeline penalties of common strategic errors. While generic chatbots reach production 83% of the time, **95% of custom enterprise solutions fail** primarily due to fragmented data foundations and the disconnection between slide-based strategy and production engineering.

Data sources: SoftTeco Research, Improving (IDC & MIT Studies), Cognizant Banking Insights

From an Enterprise Architecture (EA) perspective, traditional management consulting engagements fail in banking because they treat AI as a portfolio of isolated departmental use cases rather than a shared architectural discipline[1]. This strategy-execution gap routinely costs institutions 6 to 12 months of lost progress before internal engineering teams must re-architect and restart initiatives from scratch[3]. Generalist consulting firms typically deliver top-down use-case catalogs—listing plausible concepts such as automated underwriting, personalized wealth advisory, or document extraction—without verifying whether the underlying core banking systems, data lineage, and regulatory controls can support autonomous execution[4]. In a regulated bank, a model that performs well in an isolated sandbox fails in production because its outputs cannot be fed directly into core workflows or regulatory reporting pipelines without manual human reconciliation[9]. The bottleneck is never the raw capability of the foundation model; rather, enterprise scaling breaks down across three structural walls inside the institution's architecture[4].

The first structural barrier is the "data debt" tax and context fragmentation across Systems of Record[4]. Approximately 95% of enterprise AI failures trace back to data constraints, and 60% of AI projects lacking AI-ready data are abandoned[3]. Industry surveys indicate that only 9% of financial institutions operate as truly "data-first organizations," while 14% still rely heavily on third-party digital providers for basic data access[6]. Classic data architecture ends at the analytical dashboard, where data is clean, modeled, and aggregated for human reporting[11]. Enterprise AI architecture, by contrast, requires unstructured content at scale and a retrieval layer that carries its access rules with it, records provenance, and respects permissions at query time[11]. When consulting teams bypass foundational data engineering to build rapid PoCs on top of fragmented warehouses, data lakes, and legacy operational systems, the resulting agents lack a shared business vocabulary and authoritative context[4]. In banking, where a model hallucination constitutes a regulatory violation and a reputational crisis rather than a minor technical glitch, discovering these data gaps after development begins costs 3 to 5 times more than conducting an upfront architectural assessment[3].

The second barrier is the centralized operating model mismatch and the absence of a reusable integration harness[4]. McKinsey research shows that 70% of financial institutions organize their AI efforts around a centrally led model, such as an isolated Center of Excellence (CoE) or an innovation lab[4]. While a centralized lab is effective at building standalone demonstrations, it is structurally unsuited for enterprise-wide scaling in a financial institution[4]. Centralized teams sit outside the business units that own the profit-and-loss (P&L) statements, leading to inter-departmental friction, slow execution, and a 40% to 60% failure rate driven by human factors and lack of frontline ownership[3]. Conversely, when business units purchase one-off AI tools department by department without a shared enterprise architecture, the institution accumulates unmanageable integration debt[7]. Up to 70% of potential business value is lost in the "final mile" of adoption when AI sits in a separate application that employees never open, rather than being wired directly into existing CRMs, ERPs, ticketing systems, and core banking workflows[1].

The third barrier stems from retrofitted governance, security blind spots, and MLOps neglect[1].

Governance fails when it lives only in a corporate policy document; to clear internal risk review in banking, governance must be compiled directly into system permissions, deterministic approval rules, and immutable audit logs[1]. Treating compliance, model risk management, and explainability as a separate legal gate at the end of a pilot increases implementation costs by 3 to 5 times compared to embedding governance into the architecture from day one[3]. Simultaneously, neglecting production MLOps and LLMOps infrastructure causes up to 60% of deployed models to degrade in effectiveness within six months due to data drift, correlation-driven errors on imbalanced datasets, and shifting macroeconomic conditions[3]. Organizations also routinely cancel initiatives prematurely after 6 to 9 months when expecting immediate payback, forfeiting returns that empirically materialize at the 12-to-18-month production maturity mark[3].

Strategic Dimension	Traditional "Big Four" Consulting Approach (Failure Mode)	Enterprise Architecture-Led Approach (Production Standard)	Quantified Impact / Risk Mitigation
Architectural Philosophy	Treating AI as a string of isolated, use-case-specific pilots or department-by-department tool purchases[3].	Building a shared **Enterprise AI Reference Architecture** where one workflow establishes reusable shared services for the next[1].	Prevents fragmentation and eliminates the 6–12 months of lost progress caused by strategy-only roadmaps[3].
Build vs. Buy Strategy	Either buying rigid black-box vertical SaaS tools or attempting to build foundational infrastructure from scratch[1].	**Layer-by-Layer Build/Buy/Hybrid**: Buy commodity compute and foundation models; build proprietary context, retrieval, workflows, and evaluation sets[1].	Concentrates engineering capital on the bank's unique compliance rules and proprietary data moat[1].
Data & Foundation Rollout	Either skipping data engineering entirely	**Vertical Slice Foundation**: Pick	Avoids $150K$–400K wasted per

	(demo theater) or spending 12+ months trying to consolidate every bank schema before shipping one agent[4].	one measurable workflow, map only the fields it touches, deploy four shared services, and prove reuse on a second workflow[1].	abandoned pilot and $250K–500K per misaligned tech-first project[3].
Operating Structure	Centralized Innovation Lab / CoE disconnected from business unit P&L and core IT systems of record[4].	**Federated Hub-and-Spoke**: Central EA Hub governs infra, AI Gateway, and risk; Spokes embed engineers in P&L units[4].	Overcomes the 40%–60% failure rate caused by human factors and frontline adoption resistance[3].
Governance & Risk	Treated as a post-pilot legal gate or static policy PDF before production sign-off[1].	**Executable Architecture Controls**: UKNF, DORA, and EU AI Act controls built into permissions, approval gates, and storage logs from day one[1].	Eliminates the 3–5x cost multiplier of retrofitting explainability and compliance post-development[3].

To establish an effective Enterprise Architecture posture, the Chief Architect must combine a **Federated Hub-and-Spoke Operating Model** with a **Layer-by-Layer Build-versus-Buy Strategy**[1]. Under this framework, the bank buys commodity infrastructure—such as GPU capacity, cloud hosting, and general foundation models—while building the proprietary layers where its data, workflows, compliance rules, and evaluation sets are unique[1]. Rather than falling into the "architecture-first trap" of spending over a year consolidating every database schema across the bank before launching a single use case, the Chief Architect should mandate a **Four-Step Vertical Slice Rollout**: (1) pick one high-value workflow with a measurable baseline cost and a named P&L owner, (2) define the minimum data foundation covering only the fields that workflow touches, (3) stand up four shared architectural services (identity/gateway, retrieval, orchestration, and unified audit logging), and (4) run a strict **reuse test** by deploying a second workflow on the exact same foundation[1].

2. Global & Polish Benchmarks: Feasible Agentic AI

Approaches in Financial Services

A Chief Architect designing a bank's AI strategy must ground architectural decisions in proven production deployments across both global Tier-1 institutions and leading Polish banks[17]. Worldwide, the financial services sector is projected by McKinsey to unlock up to $1 trillion in annual value from AI, but the institutions capturing actual P&L returns today have moved decisively away from unconstrained conversational chatbots toward governed, multi-agent enterprise architectures[20].

Global Production Pioneers and Technology Stacks

At the global frontier, **JPMorgan Chase** has established the benchmark for Tier-1 banking scale, generating $1.5 billion to $2 billion in annual value across more than 300 production AI use cases[20]. Architecturally, JPMorgan Chase's flagship **OmniAI** platform exemplifies a **Hierarchical Agent System**: a central supervisor orchestrator manages hundreds of specialized domain sub-agents across risk assessment, compliance monitoring, and customer service business units[20]. This hierarchical topology provides the clear accountability chains and simplified governance required by banking supervisors, while engineering teams focus on capacity planning at the supervisor layer to prevent orchestration bottlenecks[20]. Where extreme resilience and low-latency parallel execution are required—such as algorithmic trading systems and distributed real-time fraud detection—leading global institutions complement hierarchical supervisors with **Peer-to-Peer Agent Networks** and **Hybrid Architectures**, using sequential processing for structured loan approvals and parallel execution for computationally intensive portfolio optimization[20].

In the fintech and commercial banking spheres, **Block** and **Grasshopper Bank** demonstrate how the open **Model Context Protocol (MCP)** transforms agentic integration from brittle point-to-point API coding into governed enterprise infrastructure[19]. Block engineered all of its MCP servers in-house using an enterprise MCP framework to maintain absolute security control, multi-tenant isolation, and custom workflow integration across its proprietary financial systems[19]. Similarly, Grasshopper Bank deployed MCP services in production for small business banking to power automated alerts on low-liquidity triggers and upcoming overdraft risks, real-time budgeting signals over categorized transaction flows, and predictive suggestions that adjust invoice schedules to optimize cash availability[19]. Meanwhile, **Ally Financial** operationalized a centralized, cloud-based generative AI platform utilizing standardized LLM adapters, connectors, and prompt management layers, enabling internal business units to query multiple foundation models interchangeably without vendor lock-in[6].

To support these architectures, global cloud and open-source providers have converged on standardized agentic building blocks tailored for regulated finance:

- **AWS Financial Services Stack (*Amazon Bedrock AgentCore* & *Strands Agents*)**: Provides managed multi-agent runtimes supporting both supervisor-coordinated and direct routing modes over Model Context Protocol (MCP) and Agent2Agent (A2A) protocols[20]. Production patterns include three-phase autonomous insurance and dispute claims adjudication (spanning First Notice of Loss, Intelligent Appraisal, and Autonomous Settlement) and concurrent equity research swarms powered by foundation models such

as Amazon Nova Pro[23].

- **IBM Enterprise Stack (*watsonx* & *watsonx.data*)**: Delivers pre-built financial agents equipped with over 150 integrated enterprise tools alongside a governed context layer that accesses fragmented data in place across warehouses, lakes, and mainframes—eliminating the compliance risk and latency of centralizing all bank data before agent execution[9].
- **Microsoft Enterprise Stack (*Azure AI Foundry*)**: Supplies industrial-grade cross-cloud infrastructure for layered agentic reference architectures, frequently combined with Spring AI, Azure API Management (APIM), and the Protocol Adapter Pattern to transition agent PoCs into enterprise platforms[7].
- **Open-Source Financial Frameworks (*FinRobot* & *ToolHive/Mecatl*)**: The AI4Finance Foundation's *FinRobot* provides a dedicated four-layer open-source framework for market forecasting agents, financial document analysis, and trading strategy optimization[20], while Stacklok's open-source *ToolHive* and *Mecatl* harness enable banks to run curated, VPC-isolated MCP registries inside their own private cloud environments[14].
- **Global Agentic Payment Networks (*Visa Intelligent Commerce* & *Mastercard Agentic Payments*)**: In mid-2026, Visa and Mastercard—supported by edge infrastructure partners Cloudflare and Akamai—launched cryptographic trust layers that authenticate cardholders and verify the identity of trusted AI agents, enabling consumer and B2B agents to execute autonomous purchases within deterministic user-defined spending rules[26].

Empirical Benchmarks from the Polish Banking Sector (2025–2026)

Domestic competitors in Poland have already translated these global architectural principles into production systems, diverging sharply from slide-deck consulting to prioritize sovereign or hybrid compute control, employee augmentation over reckless customer-facing autonomy, and deep core-system modernization[17].

Institution & Scope	Flagship Production AI & Agentic Initiatives (2025–2026)	Enterprise Architectural & Infrastructure Posture	Measured Production Outcomes
JPMorgan Chase *(Global Tier-1 Benchmark)*	**OmniAI Platform** orchestrating 300+ production use cases across risk, fraud, compliance, and client servicing[20].	**Hierarchical & Hybrid Multi-Agent Architecture**: Central supervisor orchestrator governing hundreds of	$1.5B$–**2B** in quantified annual business value generated from AI initiatives[20].

		specialized domain sub-agents[20].	
Block & Grasshopper Bank *(Global Fintech / Commercial)*	In-house **Enterprise MCP Services** for proprietary tool access (Block); automated liquidity/overdraft alerts and cash-flow scheduling (Grasshopper)[19].	**VPC-Isolated MCP Control Plane**: Standardized JSON-RPC context servers replacing custom point-to-point API integrations[19].	Sub-100ms context retrieval; 60%–70% cut in manual lending/AP work across industry MCP deployments[19].
PKO Bank Polski (PKO BP) *(Polish Tier-1 Leader)*	**Sovereign Email Routing Agent** (analyzing, classifying, and proposing execution paths); **szukAI** corporate KB; **Document Intelligence** (OCR + GenAI); **Visa Intelligent Commerce**[17].	**Sovereign AI & Proprietary FinLLMs**: In-house development of two Polish financial LLMs (1B and 24B parameters); open-source contributions to **Bielik** and **Sójka (Bielik-Guard)**[17].	Up to **70% faster** client email response across tens of thousands of monthly messages; **16,000+ internal users** on szukAI; **30 additional AI agents** in 2026[17].
mBank *(Polish Digital Leader)*	**Talk to Your Data** (NL-to-SQL over tens of thousands of tables); **mComplaints**; **Speech-to-Text & Automated QA**; **mKanon**; **mSmart**; **Visa & Mastercard Agentic Payments**[18].	**Zero-PoC Incubator & Core Replatforming**: Rejected isolated PoCs; built 100% in-house after full migration from mainframe to **.NET**; **on-premise Speech-to-Text** to cap cloud opex[18].	**15% reduction** in complaint handling time; **100% QA coverage** across 50,000 daily calls (10M annual interactions) vs. 1-in-1,000 manual sampling[18].
ING Bank Śląski, Bank Pekao &	**ING Business GenAI Assistant**	**Authenticated Portal &**	First authenticated AI-agent-initiated

UniCredit *(Polish Corporate & Payments)*	(corporate portal intent recognition and live handoff)[29]; **Mastercard Authenticated Agentic Transactions** (Pekao, UniCredit, mBank)[27].	**Cryptographic Agent Trust**: Phased corporate rollout (Q1 2026) and network-level agent identity verification[26].	payment transactions in Poland; streamlined corporate transaction support[27].

Three strategic lessons emerge from comparing global and Polish banking deployments. First, **core modernization and semantic data discoverability must precede agentic scale**[11]. mBank's ability to reject isolated PoCs and scale five major GenAI tools directly into production stems from its structural engineering foundation: it is the first bank in Poland to have completely migrated both retail and corporate banking off legacy mainframes onto a modern .NET platform[18]. Furthermore, recognizing that data analysts spend more time locating data across tens of thousands of database tables than analyzing it, mBank deployed *Talk to Your Data*—an internal natural-language-to-SQL agentic tool equipped with reinforcement feedback loops from analysts—to accelerate regulatory reporting and system specification checks[18].

Second, **unit economics dictate hybrid model routing and on-premise inference for high-volume operational workloads**[11]. While public cloud APIs accelerate initial experimentation, processing 50,000 voice calls per day—totaling 10 million customer interactions annually at mBank—through public cloud speech-to-text APIs generates punitive recurring operational expenditure[18]. By deploying speech-to-text models on-premise via a one-time capital allocation and applying generative AI for automated post-call synthesis, mBank transitioned from manually auditing 1 in 1,000 calls to delivering automated compliance feedback on 100% of customer conversations[18].

Third, **Sovereign AI and domain-specific small-to-medium models (SLMs) are replacing monolithic external dependencies**[11]. By August 2026, 40% of multinational enterprises globally began redesigning their AI deployment strategies to satisfy Sovereign AI mandates, where both data residency and model training or hosting remain within national borders[34]. PKO Bank Polski exemplifies this architectural posture in Poland: rather than relying exclusively on foreign hyperscaler APIs, PKO BP developed two internal Polish-language generative models specialized in finance—sized at 1 billion and 24 billion parameters—alongside contributing to the Polish open-source model ecosystem, including *Bielik* and the safety classifier *Sójka (Bielik-Guard)*, which has surpassed 900,000 downloads on Hugging Face[17]. Crucially, PKO BP built its *szukAI* corporate knowledge platform (adopted by over 16,000 employees) and its *Document Intelligence* pipeline first, establishing the verified retrieval foundation required to power its first sovereign email-routing agent and its broader 2026 roadmap of 30 additional operational AI agents[17].

3. Sample Enterprise AI Reference Architectures &

Technical Blueprint

To move from ad-hoc projects to an industrial-grade platform, the Chief Architect must establish an official **Enterprise AI Reference Architecture**[1]. Enterprise AI architecture is the shared design that connects an organization's data, models, retrieval mechanisms, agents, system integrations, and security controls so that dozens of business use cases run safely on one governed foundation[1]. Across global industry practice in 2026, three sample reference architectures provide complementary views that a bank should synthesize: the **Eight-Layer & Two-Plane Enterprise Stack**, the **Five-Layer Systems-of-Record Integration Blueprint**, and the **Three-Layer Event-Driven Process Intelligence Stack**[1].

Comparative Analysis of Sample Enterprise AI Reference Architectures

Reference Architecture Model	Core Structural Layers & Cross-Cutting Planes	Primary Architectural Strength in Banking	Key Design Rules & Operational Guardrails
Blueprint A: The 8-Layer & 2-Plane Enterprise Reference Architecture *(Kanerika / SotaTek Enterprise Model)*[1]	**Horizontal Layers**: (1) Infrastructure & Compute, (2) Data Foundation, (3) Retrieval & Knowledge, (4) Model & Router Layer, (5) Orchestration & Agents, (6) Integration Layer, plus **2 Vertical Cross-Cutting Planes**: (7) Security & Governance Plane and (8) Observability & LLMOps Plane[1].	Assigns **one clear owner and one set of decisions per layer**[1]; separates commodity compute/models (Buy) from proprietary context, retrieval, and evaluation sets (Build)[1].	Enforces **permission-aware retrieval** at query time before the model answers, and **portfolio model routing** to dispatch simple tasks to low-cost SLMs[1].
Blueprint B: The 5-Layer Systems-of-Record Integration	(1) **Channels** (Teams, inbox, CRM/ERP events), (2) **Stateless Agent**	Strictly isolates core banking ledgers from probabilistic models;	The Agent **holds zero database credentials** and makes **no final**

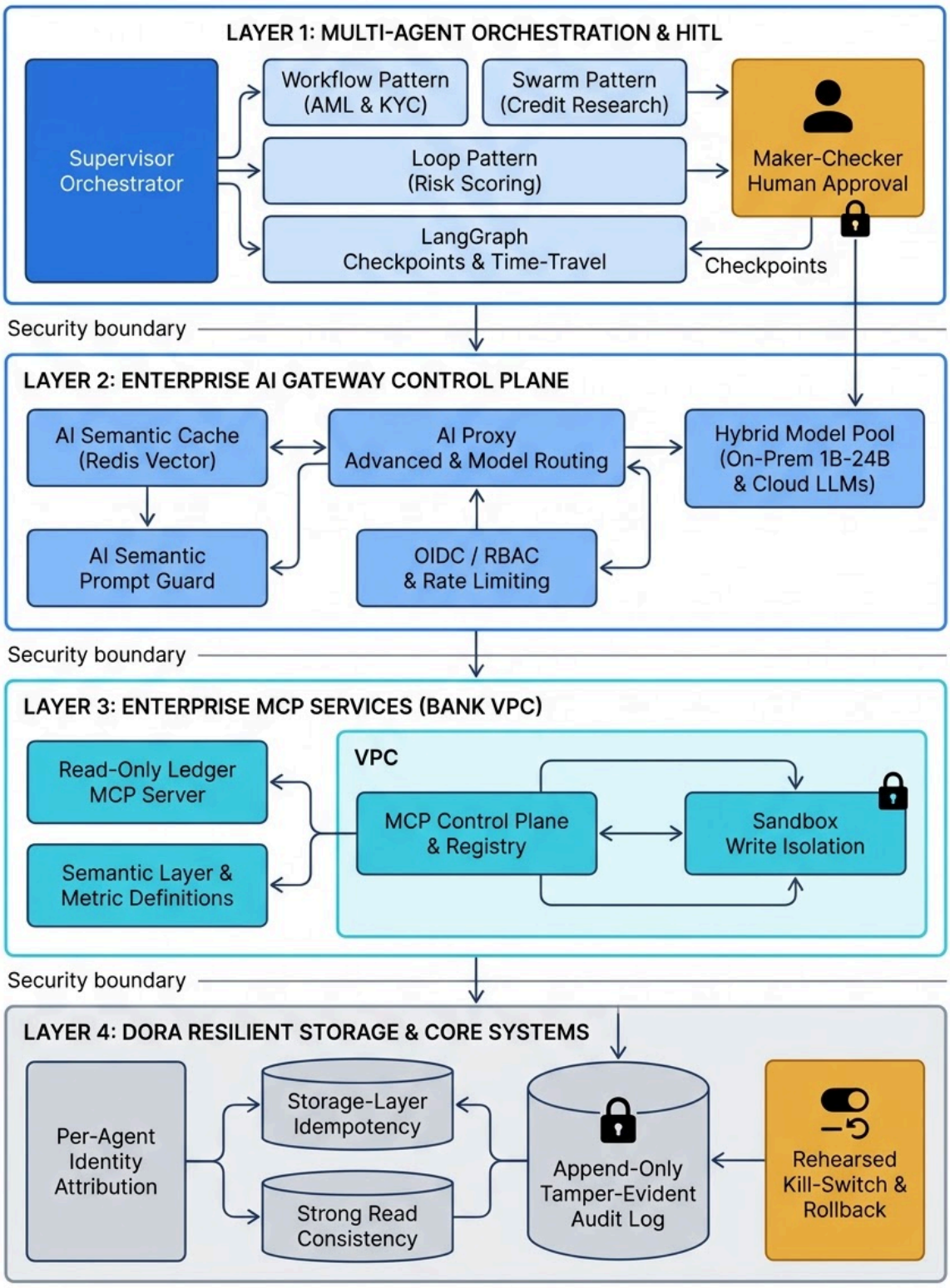
Architecture *(Ovidius ERP / Core Banking Protection Model)*[12]	(LLM with instructions), (3) **Integration & Rules Harness**, (4) **Systems of Record** (Core Banking, ERP, CRM, Warehouse), (5) **Unified End-to-End Audit Log**[12].	concentrates engineering and risk controls inside the intermediate **Integration Harness**[12].	**decisions on money or access**; reads hit a synced cache/warehouse first so core systems are never overloaded[12].
Blueprint C: Tier-1 Cloud-Native & Event-Driven Agentic Architecture *(Adastra / JPMorgan / Waehner Process Model)*[20]	Combines **Event-Driven Integration** (real-time streaming pipelines & data lakehouse), **Process Intelligence & Semantic Layer**, and **Trusted Multi-Agent Execution** (Hierarchical Supervisor + Swarm/Peer-to-Peer sub-agents)[20].	Engineered for Tier-1 banks operating across millions of low-latency transactions, real-time fraud detection, and cross-departmental workflow automation[20].	Separates **Systems of Record** (deterministic state) from **Systems of Action** (agentic execution) using asynchronous event streams and CISA-aligned immutable logging[10].

End-to-End Request Lifecycle Across the Enterprise Stack

When synthesizing these reference models into a unified banking blueprint, every user prompt or event trigger must traverse a deterministic **Eight-Step Request Lifecycle** across four core technical subsystems[1]:

1. **Entry & Identity Verification**: The request arrives via a conversational channel, internal workbench, or event stream and hits the **Enterprise AI Gateway**, which authenticates the user's corporate identity (OIDC/SAML), verifies role-based access control (RBAC) permissions, and enforces token rate limits and departmental budget ceilings[1].
2. **Input Guardrails & Semantic Cache Check**: The gateway screens the input for prompt injection, blocked intents, and sensitive PII, then queries a vector-based semantic cache to check if a verified answer to a semantically equivalent request already exists[11].
3. **Stateful Orchestration**: If the cache misses, the orchestrator (e.g., LangGraph) classifies the intent, selects the appropriate deterministic workflow or multi-agent topology, and initializes a replayable state graph[1].

4. **Permission-Aware Retrieval & Semantic Grounding**: Before calling a model or writing SQL, the system retrieves context from vector indexes, knowledge graphs, and the governed financial semantic layer—filtering all documents and rows strictly by the requesting user's access rights at query time, never after the model generates an answer[1].
5. **Model Portfolio Routing**: The router dispatches each sub-task to the optimal model tier—using Small Language Models (SLMs) or sovereign fine-tuned models (1B–24B parameters) for classification, summarization, and entity extraction, while reserving frontier models for complex multi-step reasoning[7].
6. **Governed Tool Invocation via MCP Services**: When the agent must interact with external systems, it invokes tools exposed by VPC-isolated **Enterprise MCP Services**; the integration harness authenticates as the requesting user, reads from a synced warehouse/cache to protect core mainframes, and formats any proposed state changes[12].
7. **Output Guardrails & Maker-Checker Human Gate**: Output screening validates factual grounding against retrieved context to prevent confabulation[11]. If the action involves moving money, altering credit limits, or submitting regulatory data above defined thresholds, execution pauses at a stateful **Human-in-the-Loop (HITL) checkpoint** for explicit human sign-off[12].
8. **Transactional Execution & Unified Audit Logging**: Approved writes execute against a DORA-compliant database with storage-layer idempotency, while every layer writes a single unified trace record—capturing prompt, model version, records read, tool called, rule applied, human approver, and final result—to an append-only audit log[11].



Deep Dive into the Four Core Architectural Subsystems

Subsystem 1: Multi-Agent Topologies, LangGraph Orchestration, and

Maker-Checker Controls

Production banking architectures must align the specific multi-agent coordination topology with the risk profile, latency tolerance, and dependency structure of the underlying banking workflow[20]. Rather than treating all agentic systems as uniform autonomous loops, enterprise architects categorize multi-agent topologies into four distinct patterns alongside two prohibited anti-patterns[20].

Agentic Pattern / Anti-Pattern	Architectural Mechanism & Reasoning Paradigm	Primary Banking & Financial Services Use Cases	Operational Trade-Offs & Governance Constraints
Workflow Pattern (Sequential & Parallel)	Decomposes complex processes via chain-of-thought into deterministic steps where each agent validates output before passing state forward[23].	**AML/KYC Compliance** (ID verification to PEP screening and enhanced due diligence); **Autonomous Claims & Dispute Adjudication**[23].	Delivers high accuracy and linear regulatory audit trails, but overall latency is bounded by the slowest agent in the chain[23].
Swarm Pattern (Collaborative Concurrent)	Multiple specialized agents execute concurrently over shared memory and foundation models to synthesize heterogeneous inputs[23].	**Equity & Credit Research** (parallel agents analyzing stock prices, financial metrics, company profiles, and news sentiment)[23].	Compresses multi-hour analyst research into minutes, but requires strict shared-memory coordination[23].
Loop Pattern (Reflective Reasoning)	Iterative processing cycles where evaluation agents critique and refine outputs against quality thresholds until convergence[23].	**Credit Scoring Refinement**, **Algorithmic Trading Simulation**, and **Dynamic Pricing Optimization**[23].	Enables dynamic self-improvement, but requires strict termination conditions to prevent runaway infinite loops and token exhaustion[23].

Hybrid Hierarchical Pattern	Supervisor orchestrator directs specialized sub-agents sequentially for governance while running compute-heavy tasks in parallel[20].	**Enterprise Platforms** (exemplified by JPMorgan Chase's *OmniAI* managing hundreds of domain sub-agents across business units)[20].	Provides clear regulatory accountability chains, though supervisor capacity must be engineered to avoid bottlenecks[20].
Anti-Pattern: Large Singleton *(Prohibited)*	Overloading a single agent with excessive tools and responsibilities (e.g., risk modeling, commissions, broker chat, and KB search)[23].	Misconfigured monolithic underwriting or customer service agents[23].	Causes tool confusion, malformed function arguments, inconsistent outputs, high latency, and inflated token costs[23].
Anti-Pattern: Agent Washing *(Prohibited)*	Wrapping a single deterministic script, Lambda function, or single tool inside a multi-agent supervisor purely for marketing optics[23].	Over-engineered simple automation workflows[23].	Introduces unnecessary orchestration latency and failure points where deterministic API calls suffice[23].

For macro-orchestration, banking engineering teams standardize on graph-based stateful orchestration frameworks such as **LangGraph**, often deployed alongside managed cloud runtimes including AWS Bedrock AgentCore, Strands Agents, Microsoft Azure AI Foundry, or IBM watsonx[20]. Unlike unconstrained autonomous agent loops, LangGraph models workflows as explicit state graphs supporting interrupt-and-resume checkpoints and time-travel debugging[37]. This capability enforces banking's foundational **Maker-Checker** rulebook: the AI agent acts as the "Maker" by gathering KYC evidence across jurisdictions, drafting credit memos, or preparing payment instructions, and execution pauses deterministically at a graph checkpoint until an authorized human "Checker" reviews, modifies if necessary, and cryptographically approves any action that moves money, exceeds transaction thresholds, or communicates with a regulator[38].

Subsystem 2: The Enterprise AI Gateway Control Plane

Allowing individual banking applications or agents to call external or internal LLM APIs directly creates unmanageable security, cost, and compliance sprawl[15]. Every request—whether

User-to-LLM, Agent-to-Agent (A2A), or Agent-to-Tool via MCP—must traverse a centralized **Enterprise AI Gateway**[15]. A critical architectural decision for the Chief Architect is selecting between developer-centric proxies such as LiteLLM or Portkey, managed AI gateways such as TrueFoundry, and enterprise API control planes such as Kong AI Gateway[13]. While LiteLLM offers rapid configuration-based model switching across providers, its open-source core decentralizes governance into application-level virtual keys, lacks unified precedence rules when rate limits overlap across keys, teams, and users, and does not provide standard enterprise patching SLAs or SLSA attestations—frequently turning into a costly internal reliability project as scale increases[13]. Conversely, extending an enterprise API management platform like Kong AI Gateway unifies APIs, event streams, LLM calls, MCP tool invocations, and A2A traffic under a single policy layer integrated with corporate OIDC, LDAP, and SAML identity providers[13]. In production stress benchmarks running 400 concurrent virtual users with 1,000-token prompts across 12 CPUs, Kong's data plane demonstrated over 200% higher throughput than Portkey and over 800% higher throughput than LiteLLM[48].
Regardless of vendor selection, the bank's AI Gateway must enforce four foundational capabilities across the request lifecycle[15]:

1. **Vector-Based Semantic Caching**: Embedding incoming prompts (e.g., via text-embedding-3-large or sovereign local embeddings) and querying a high-speed vector store such as Redis 8.0 to identify semantically equivalent prior queries[15]. Returning cached validated responses without invoking the LLM reduces monthly inference token costs by 40% to 70% and compresses response latency from 850 milliseconds to under 120 milliseconds (a 3-to-4x average speedup and up to 10x acceleration on repetitive banking queries)[15].
2. **Semantic Prompt Guarding & Inline Runtime Security**: Layering semantic intent blocking and inline context evaluators (such as Straiker) over traditional regex allow/deny lists to block prohibited intents, prompt injections, or unauthorized tool trajectories before an agent action executes[11].
3. **Portfolio Model Routing & Lifecycle Management**: Treating fine-tuned domain models (such as separate Retail Banking and Mortgage & Lending assistants), Small Language Models (SLMs), and sovereign models (like PKO BP's 1B and 24B parameter models) as versioned products supporting blue/green deployments, canary releases, and multi-cloud failover[11].
4. **Granular Composable Rate Limiting & Token Budgets**: Enforcing token and cost ceilings across consumer, team, route, and service tiers to prevent runaway loop expenditure[13].

Subsystem 3: Standardized Context and Tooling via Enterprise MCP Services

The primary reason enterprise AI agents stall before production is the inability to safely connect models to fragmented internal systems of record without building brittle point-to-point API integrations or suffering from "Context Rot"[9]. Anthropic's open **Model Context Protocol (MCP)**—operating via JSON-RPC 2.0 messages across an MCP Host (the AI application), MCP Clients (connectors), and MCP Servers (which expose curated tools and data resources)—has

become the universal standard for financial services[22]. Across financial institutions implementing MCP for lending, accounts payable three-way matching, and risk analysis, organizations report cutting manual processing work by 60% to 70%, improving fraud detection accuracy by 50%, increasing customer satisfaction by 30%, and achieving positive ROI within 5 months[19].

However, the Chief Architect must enforce a strict architectural distinction: the MCP specification explicitly leaves access control to the implementer and cannot guarantee security at the bare protocol level[30]. Most early open-source MCP servers are local-first, desktop-centric, single-player implementations lacking multi-tenancy and governance[19]. A regulated bank must instead deploy **Enterprise MCP Services**—leveraging VPC-hosted platforms such as Stacklok/ToolHive, Arcade, or custom in-house implementations like Block—that run entirely inside the bank's Virtual Private Cloud so sensitive data never leaves the institution's infrastructure[14]. Production MCP services must also meet strict financial latency thresholds: under 100 milliseconds for context retrieval (300ms maximum ceiling) and under 200 milliseconds for standard API tool responses (500ms critical threshold)[19].

Subsystem 4: DORA-Compliant Transactional Storage and Operational Resilience

When an agentic system transitions from an internal pilot to a customer-facing or operations-scale service running hundreds of concurrent read $\rightarrow$ decide $\rightarrow$ write $\rightarrow$ verify loops per second, traditional database architectures exhibit severe failure modes[44]. Under the EU Digital Operational Resilience Act (DORA), EU AI Act Article 12, and CISA's Logging Reference Architecture (August 2026), database infrastructure is the primary compliance evidence generator[12].

Storage & Resilience Control	Architectural Implementation in the Banking Estate	Failure Mode if Omitted at Agent Scale	Regulatory Mandate Satisfied
Append-Only Audit Storage	Immutable, tamper-evident write-once logs enforced directly at the database storage layer capturing agent ID, tool arguments, results, policy checks, and synchronized timestamps[12].	Mutable application logs can be altered by administrators or attackers, invalidating forensic reconstruction during regulatory audits[16].	**DORA** (Logging & Event Reconstruction), **EU AI Act Art. 12 & Art. 18** (10-year retention), & **CISA Logging Reference Architecture**[12].

Per-Agent Identity Attribution	Every database write and state transition carries a dedicated cryptographic agent identity linked to its authorizing human/system policy[16].	Shared service accounts make it impossible to reconstruct which agent executed an erroneous transaction or under what authority[30].	**DORA Art. 9** (IAM Controls) & **EU AI Act Art. 12** (Traceability)[44].
Strong Read Consistency	Distributed SQL architecture guaranteeing linearizable, strong read consistency across all database nodes globally or regionally[44].	Agents acting on stale reads across asynchronous replicas trigger race conditions, double-spends, and duplicate credit issuances at machine speed[44].	**DORA** (Transaction Integrity & Operational Resilience)[44].
Storage-Layer Idempotency	Enforcing idempotency keys natively at the database storage tier rather than relying on application-layer deduplication[44].	Network timeouts trigger automatic agent tool retries, resulting in duplicate payments or ledger postings under concurrent load[44].	**DORA** (ICT Risk Management & Payment Integrity)[16].
Compensating Transactions & Kill-Switch	Automated rollback paths for partial workflow failures paired with an isolated, per-agent **Kill-Switch** and dual-control restart[16].	Inability to halt a malfunctioning agent without taking down core banking services or leaving orphaned, unreconciled ledger states[16].	**DORA Art. 24–27** (Resilience Testing) & **EU AI Act Art. 14** (Human Intervention/Stop)[16].

4. In-Depth AI Agent Architecture Diagnostic Framework: Evaluating What Works vs. What Fails

Before approving new budgets or scaling existing pilots, the Chief Architect needs a rigorous

AI Agent Architecture Diagnostic Framework to audit the institution's current landscape, terminate dysfunctional "zombie pilots," and identify what actually works in production[1]. This diagnostic is structured into four operational instruments: (1) The 7-Day High-Privilege Agent Audit, (2) The 8-Layer Enterprise Governance Readiness Scorecard, (3) The Architectural Pattern Diagnostic Matrix (What Works vs. What Fails), and (4) The Staged Agent Permission & MCP Governance Checklist[1].

Instrument 1: The 7-Day CIO / Chief Architect Self-Diagnostic ("Top-3 Privileged Agents Test")

To immediately gauge whether the bank is ready for enterprise agentic AI, the Chief Architect should select the **three highest-privilege AI agents or workflows currently in production (or late-stage pilot)** and require the engineering and business teams to document five foundational attributes within one week without consulting external vendors[12]:

1. **Named Accountability**: Who owns each agent by individual name (both the technical deployment owner and the P&L business owner), and who signed off on its current risk tier?[4]
2. **Change Control Lineage**: What changed in the agent most recently (prompt template, model weight/version, temperature, orchestration graph, or tool schema), and who cryptographically approved that change before promotion?[12]
3. **Connector & Knowledge Blast Radius**: Exactly which internal APIs, MCP servers, databases, and knowledge bases can the agent reach, and are those boundaries enforced via scoped network/IAM permissions rather than system-prompt instructions ("model promises")?[14]
4. **Execution Identity & Delegation**: Under whose credentials do the agent's reads and writes execute—does it impersonate a shared administrator service account (an immediate audit failure), or does it authenticate per-request under the invoking user's RBAC identity alongside a unique per-agent cryptographic ID?[12]
5. **Kill-Switch & Rollback Verification**: If the agent begins hallucinating or executing erroneous writes right now, can operators trigger an isolated stop that halts the agent with zero subsequent actions while leaving core banking and adjacent agents untouched, and can they produce an immediate list of every record modified for rollback?[16]

Diagnostic Scoring Rule: If the organization cannot answer all five questions for its top three workflows with verifiable system artifacts within 48 hours, the institution has an **unmanaged Shadow-Agent estate** and must freeze new autonomous write deployments until the Enterprise AI Gateway and MCP Control Plane are operationalized[15].

Instrument 2: The 8-Layer Enterprise AI Governance & Readiness Scorecard

Enterprises routinely skip readiness reviews in their rush to launch demos, incurring massive hidden remediation costs later[3]. The Chief Architect should score the bank's current platform from **Level 1 (Ad-Hoc / Failing)** to **Level 3 (Production-Grade Banking Standard)** across eight mandatory governance dimensions[1]:

Governance & Architectural Dimension	Level 1: Ad-Hoc / Pilot Purgatory (What Fails in Banking)	Level 2: Transitional / Emerging (Partial Control)	Level 3: Mature Enterprise Architecture (What Works in Production)
1. Roles, Groups & Identity[44]	Shared API keys or generic service accounts used across teams and agents[30].	Application-level virtual keys (e.g., basic proxy keys) with manual user mapping[13].	Granular OIDC/SAML RBAC per user and unique cryptographic identity per agent on every read/write[13].
2. Scope & Tool Boundaries[23]	"Large Singleton" agents given broad database access and dozens of uncurated tools[12].	Agents restricted by prompt instructions ("do not call tool X") rather than infrastructure controls[16].	Least-privilege, job-matched MCP servers where write tools are physically absent from read-only configurations[1].
3. Data Access & Retrieval[1]	Unfiltered RAG over raw document dumps; post-generation redaction of unauthorized data[1].	Static departmental vector stores lacking real-time synchronization or formal metric definitions[11].	**Permission-aware retrieval** filtering documents by user rights at query time + **governed semantic layer** for SQL[1].
4. Change Control & Lifecycle[36]	Developers editing prompts or swapping models directly in application code without regression testing[7].	Basic Git versioning of prompts without automated evaluation benchmarks or canary routing[49].	Full LLMOps lifecycle with automated bias/factuality evals, blue/green gateway routing, and 10-year Annex IV archives[36].
5. Publication & Triage[8]	Any team or external consultant	Central Innovation Lab reviews ideas	Strict **6-Point Use-Case Triage**;

	can spin up a PoC on sanitized data without a business case[3].	but lacks P&L ownership or core IT integration sign-off[4].	parallel PoCs tested on real users with written pass/fail criteria and P&L owners[4].
6. Org-Wide Policy & Guardrails[36]	Policy exists only as a compliance PDF; relies on developers remembering to code regex filters[1].	App-specific input/output filters duplicated inconsistently across different squad repositories[13].	Centralized **AI Gateway** enforcing semantic prompt guards, PII tokenization, and NIST AI 600-1 controls across all traffic[15].
7. Observability & Auditability[16]	Standard mutable application logs; unable to reconstruct multi-step agent trajectories after an error[16].	Token and latency dashboards active, but lacking storage-layer immutability or decision-pathway state[44].	Append-only WORM run records (ISO/IEC DIS 24970 Clause 8.3.1) integrated with SIEM (Splunk/Datadog) for <4h DORA replay[14].
8. Core System Integration[12]	Agents query core mainframes/ERPs directly or sit in isolated chat UIs requiring manual copy-paste[1].	Point-to-point custom API wrappers rewritten every time a foundation model or vendor changes[7].	5-Layer Integration Harness: reads hit synced cache/warehouse; writes pass through deterministic rules and Maker-Checker gates[12].

Instrument 3: Diagnostic Matrix of What Works vs. What Does Not Work in Particular Organizations

Different organizational structures and workload characteristics cause specific AI approaches to succeed or fail. The Chief Architect should use the following diagnostic matrix to match technical patterns to organizational realities[1]:

- **When Choosing Between Fixed Workflows, Single Agents, and Multi-Agent Topologies**:
  - *What Fails*: Deploying fully autonomous, open-ended multi-agent loops for deterministic,

regulated banking processes (or conversely, "Agent Washing" by placing a multi-agent supervisor over a single tool/Lambda function)[1]. Autonomous agents cost significantly more in token overhead, introduce unpredictable latency, and are much harder to test and certify for compliance[1].

- *What Works*: Use a **deterministic workflow with a bounded agent step inside it** whenever the process sequence is known (e.g., loan origination, KYC onboarding, complaint routing)[1]. Reserve dynamic, tool-selecting multi-agent architectures (such as **Swarms** or **Hierarchical Supervisors**) strictly for workloads where the execution path varies dynamically based on intermediate findings—such as cross-system equity/credit research or complex multi-signal fraud correlation[1].

- **When Integrating with Legacy Core Banking Systems vs. Modernized Platforms**:
  - *What Fails*: In banks still operating legacy mainframes or heavily siloed ERPs, allowing agents to execute direct read queries or synchronous API calls against core systems of record[9]. High-concurrency agent loops (read $\rightarrow$ decide $\rightarrow$ write) will rapidly overload legacy transactional databases and trigger operational outages[12].
  - *What Works*: If the bank has completed core replatforming (such as mBank's migration from mainframe to .NET), internal incubators can deploy broader agentic services directly over modern APIs[18]. If the bank still relies on legacy core systems, what works is an **asynchronous Cache/Warehouse Read + Staged Integration Harness**: agents read exclusively from a synchronized data lakehouse, warehouse, or in-memory cache (or via in-place federation like IBM watsonx.data), while all writes are queued, rate-limited, and routed through deterministic ERP/core workflows[9].
- **When Designing Data Access for Financial & Regulatory Analysis**:
  - *What Fails*: Expecting an LLM to write accurate SQL directly against tens of thousands of raw, poorly documented bank database tables, or mixing RAG, knowledge graphs, and semantic layers without clear architectural boundaries[7]. Retrieval alone is not understanding; without unified metric definitions, the model will hallucinate calculations and violate regulatory reporting definitions[7].
  - *What Works*: Pairing an NL-to-SQL assistant with a **Governed Financial Semantic Layer** (where chart-of-accounts mappings, currency conversions, intercompany matching, and fiscal calendars execute as versioned rules *before* the agent writes SQL) and incorporating continuous human analyst reinforcement feedback loops[11].
- **When Scaling Organizational Ownership (Centralized CoE vs. Federated Spokes)**:
  - *What Fails*: Keeping AI engineering locked inside a centralized Innovation Lab or IT department without P&L business sponsorship, or hiring strategy-only consultants who deliver slide decks without production engineers[3]. Frontline banking advisors and operations staff will reject or bypass tools they do not own[3].
  - *What Works*: A **Federated Hub-and-Spoke model** focused on **employee augmentation rather than replacement**[4]. For example, in software engineering, generative AI coding tools often yield modest benefits for senior full-stack architects but deliver massive productivity gains for junior/entry-level developers learning syntax and

internal frameworks[6]; similarly, in banking operations (like PKO BP and mBank), agents that eliminate repetitive email triage, complaint drafting, and call QA free human specialists to handle complex client relationships[17].

Instrument 4: The Staged Permission Progression & 7-Decision MCP Governance Gate

To prevent catastrophic operational failures, the Chief Architect must mandate that no AI agent is ever deployed directly into production with autonomous write privileges[1]. Every agentic workflow must earn its autonomy by progressing through a **Three-Stage Permission Maturity Model** based on measured empirical runs[12]:

- **Stage 1: Read-Only Mode**: The agent answers questions, synthesizes corporate profiles, and drafts summaries exclusively from a read-only cache, warehouse, or knowledge base[12]. Nothing it does can alter a system of record, and its MCP server configuration physically excludes all write tools[12].
- **Stage 2: Draft & Maker-Checker Mode**: The agent prepares the structured transaction record—such as a credit memo, a complaint response, a CRM update, or an AML SAR draft—and pauses at a LangGraph checkpoint[12]. A named human "Checker" must review and approve every single draft before it posts to the target system, allowing the bank to measure accuracy and error rates under real production load[12].
- **Stage 3: Write Within Deterministic Limits**: Once empirical metrics from Stage 2 prove where automation is safe, the business P&L owner and Model Risk Management define strict quantitative thresholds[12]. The agent is permitted to post routine records automatically below that threshold (with idempotency and kill-switch protection), while every transaction exceeding the limit or exhibiting low confidence is routed deterministically to a human approver[12].

Furthermore, before connecting any agent to financial data via the Model Context Protocol (MCP), the Architecture Review Board must verify that **seven governance decisions** have been signed off by their respective domain owners[30]:

1. **Scope the Data (*Owner: Group Controller*)**: Expose only mapped general ledgers, consolidation tables, and metric definitions; strip out raw ERP exports, payroll records, and bank credentials, and pass only tokenized cardholder/account numbers to fraud and risk agents[30].
2. **Match the Server to the Job (*Owner: Finance Systems Lead*)**: Isolate MCP servers by domain boundary—running separate servers for external market data, single-ERP transaction workflows, and cross-entity consolidated queries[30].
3. **Default to Read-Only (*Owner: Finance Systems Lead*)**: Verify that the server's actual exposed tool manifest contains zero write tools, ignoring untrusted client-side read-only annotations[30].
4. **Enforce Per-Person & Per-Agent OAuth (*Owner: Security Architect*)**: Authenticate every tool call under the invoking user's RBAC role and a dedicated agent ID, strictly prohibiting shared admin tokens[14].
5. **Ground Queries in Formal Definitions (*Owner: FP&A / Data Lead*)**: Force the assistant

to load official metric definitions, fiscal calendars, and entity scopes from the semantic layer before generating SQL[11].

6. **Isolate All Writes (*Owner: Controller & Lead Data Engineer*)**: Route any agent-proposed changes to data or reporting logic to a sandbox or development branch with a named human approver, keeping final ledger posting inside the core system's native workflow[12].
7. **Audit the Tool Log at Financial Close (*Owner: Internal Control / Audit*)**: Review the immutable MCP tool-call log at periodic close alongside privileged access logs and archive it with regulatory close evidence[14].

5. Navigating the Polish & EU Regulatory Trilemma: UKNF, EU AI Act, and DORA

A common misconception in financial institutions is treating the EU AI Act, DORA, and Polish national supervision (UKNF) as separate legal workstreams requiring duplicate compliance bureaucracy[16]. As the European Banking Authority (EBA) confirmed in its landmark November 21, 2025 factsheet (*AI Act: implications for the EU banking and payments sector*), the EU AI Act contains no significant contradictions with existing EU financial services legislation; rather, its requirements layer directly onto existing sectoral frameworks[52]. The Chief Architect's objective is to design a **Single Governed-Agent Control Set** where one architectural mechanism satisfies all three regulatory regimes simultaneously[16].

BANKING AI COMPLIANCE BLUEPRINT & ARCHITECTURE

Regulatory Convergence Timeline and Control Mapping for **Polish Banking AI** (2025–2027)

Interactive dual-track view for Chief Architects: Chronological regulatory enforcement dates (top) aligned with a unified architectural control matrix across the EU AI Act, DORA, and Polish UKNF requirements (bottom).

1. Enforcement Milestones & Standardization Horizon

Select any milestone to reveal corresponding architectural deliverables & legal exposures.

All (9) | AI Act | DORA | UKNF / EBA

Jan 17, 2025 DORA In Force — Regulation (EU) 2022/2554
DORA Full Application (Directly Binding EU Law)
Applies directly across all 21 categories of financial entities. Strict 4-hour major incident reporting & resilience frameworks activate.
Fines up to 2% global turnover

Feb 2, 2025 EU AI Act — Article 5 Prohibitions
Prohibited AI Practices Enforceable
Total ban on social scoring, untargeted biometric scraping, and cognitive behavioral manipulation. Bank AI registry required.
Fines up to €35M / 7% turnover

Nov 21, 2025 EBA Factsheet — Banking Sector Mapping
EBA Confirms Credit Scoring & AML as High-Risk
Affirms alignment with existing financial directives. Flags unresolved high-risk status of algorithmic trading systems.
Scope Clarification

Feb 2, 2026 EC Mandate — Classification Guidelines
European Commission High-Risk Classification Guidelines
Statutory deadline for the EC to publish binding guidance defining high-risk perimeter exceptions and edge cases.
6-Month Runway Left

Mid-2026 NCA / UKNF — Supervisory Inspections
Supervisors Expect Demonstrable High-Risk Progress
EBA guidance instructs NCAs (including UKNF) to audit draft Annex IV technical files and Model Risk governance.
Audit Exposure

Aug 2, 2026 CRITICAL DEADLINE — Annex III High-Risk Enforcement
Full Compliance Mandatory: Credit Scoring, Underwriting, & AML AI
No Grandfather Clause: Legacy models deployed before Aug 2024 must achieve full compliance. Mandatory Articles 9–15 conformity, logging (Art. 12), and EU registration.
Fines up to €30M / 6% turnover

⚠ **ARCHITECTURAL ALERT: THE ARTICLE 12 LOGGING STANDARDIZATION GAP (AUG 2026 VS Q4 2026+)**
High-Risk legal enforcement activates on Aug 2, 2026, mandating automatic audit-trail logging (Art. 12). However, CEN-CENELEC's harmonized technical standard **ISO/IEC DIS 24970 Clause 8.3.1** will not be finalized until **Q4 2026 at the earliest.** Polish banks cannot wait for standardized vendor packages: architecture teams must implement self-assessed, immutable event logs using DORA run-record primitives immediately.

Q4 2026+ CEN-CENELEC JTC 21 — ISO/IEC DIS 24970
Earliest Finalization of AI Logging Technical Standard
Clause 8.3.1 codifies auditability of ML model state information and decision pathways after the legal high-risk deadline has passed.
Lagging Standard

Aug 2, 2027 Transition Horizon — Article 111 AI Act
Article 111 Transition Closes (Existing Regulated Products)
Digital Omnibus window expires. High-risk systems embedded in pre-existing large products reach final statutory transition date.
Final Window

ACTIVE INSPECTION: AUG 2, 2026 — EU AI ACT • ANNEX III ENFORCEMENT

Mandatory High-Risk AI System Enforcement & Conformity Assessment

All credit assessment, credit scoring, and AML transaction monitoring systems in production must meet Articles 9–15 obligations. Because **no grandfather clause applies**, any legacy model deployed prior to August 2024 is strictly subject to conformity requirements.

KEY REGULATORY ARTICLES	ENGINEERING DELIVERABLE	NON-COMPLIANCE EXPOSURE
Articles 9, 10, 12, 14, 18; Annex III item 5(b) & 6; Annex IV	Self-assessed Annex IV technical documentation file & 10-year retention archive	Up to €30,000,000 or 6% of total global annual turnover

2. Unified Architectural Control Mapping Matrix

How a single robust technical architecture satisfies EU AI Act, DORA resilience, and Polish UKNF requirements simultaneously.

Architectural Control	EU AI Act (2024/1689)	DORA (EU 2022/2554)	Polish UKNF Mandates
1. Immutable Logging & Decision Replay WORM-compliant run records & decision pathways	**Article 12:** Automatic event logging across operational lifetime. Auditability of input vectors, model state, and scoring output.	**Articles 5–16:** Replayable run records, unique agent identity per action, tool invocation records, tamper-evident logs.	**Komunikat Chmurowy:** Mandatory log collection and continuous monitoring in cloud environments.
2. Model Risk & Data Governance Inventory, bias checks, and lifecycle audits	**Articles 9 & 10:** Continuous documented risk management; datasets must be representative, error-free, and vetted for bias.	**Articles 5–16:** ICT risk management framework approved and continuously reviewed by executive management body.	**Rekomendacja W (Rek 1, 4, 8):** Complete Model Register for 100% of models; formal criteria for data preparation and model quality.
3. Human Oversight & Kill-Switch Operational override & rollback drill	**Article 14:** Human-in-the-loop oversight with genuine operational capacity to pause, reverse, or override credit decisions.	**Articles 24–27:** Rehearsed "stop drill" kill-switch: zero downstream writes post-stop, write list rollback, two-person restart sign-off.	**Stanowisko AML & Rek. W:** Documented executive sign-off; designated deputy roles for board member (Art. 7) & AMLRO (Art. 8).
4. Third-Party & Cloud Vendor Controls LLM API, cloud hosting, and exit strategies	**Articles 13 & 25:** Upstream provider vs deployer responsibility boundaries; 10-year conformity document retention.	**Articles 28–44:** Register of information for ICT third-party arrangements, mandatory audit rights, and viable exit/portability plans.	**Komunikat Chmurowy:** UKNF notification within 30 days of production start; strict "outsourcing szczególny" compliance.
5. Incident Escalation & Post-Market Root cause reconstruction under regulator deadlines	**Article 73:** Serious incident reporting and mandatory continuous post-market surveillance system for high-risk models.	**Articles 17–23:** Initial notification to competent authority within 4 hours of major ICT incident classification.	**UKNF Oversight:** Audit findings for procedure deficiencies (19.39% of 2024 KNF AML irregularities involved internal governance).

Tip: Click any matrix row to populate specific technical architecture recommendations in the inspector above.

Chronological enforcement milestones and architectural convergence across EU and Polish banking regulations. Because **no grandfather clause** applies to legacy high-risk systems and harmonized CEN-CENELEC logging standards (ISO/IEC DIS 24970) lag behind enforcement, Polish banks must implement self-assessed conformity and unified DORA/UKNF logging controls immediately.

Data sources: European Banking Authority (EBA), UKNF Rekomendacja W, UKNF Komunikat Chmurowy (EY), UKNF Stanowisko AML/CFT, Alice Labs, Zenity DORA Research, Moring.ai, Veritas Chain

The EU AI Act (Regulation 2024/1689) and the Standardization Gap

Under Annex III of the EU AI Act, banking systems are not classified as high-risk merely because the deployer is a bank; classification is strictly use-case driven[64]. Two core banking domains fall unambiguously under the High-Risk Annex III regime, carrying administrative fines of up to €30 million or 6% of global annual turnover, with no grandfather clause exempting legacy systems deployed prior to August 1, 2024[52]. The first high-risk domain is **Creditworthiness and Credit Scoring** under Annex III, Point 5(b), which encompasses any AI system evaluating retail or corporate credit applications, mortgage approvals, or robo-advisors that incorporate creditworthiness or financial capacity assessments[52]. The second high-risk domain is **AML/CFT Transaction Monitoring and Fraud Detection** under Annex III, Point 6; the EBA's November 2025 mapping report explicitly confirmed that AI used for Anti-Money Laundering and Counter-Terrorist Financing transaction monitoring at supervised institutions falls under high-risk obligations, whereas pure payment fraud detection devoid of AML elements requires individual classification assessment[52]. Conversely, pure algorithmic trading systems without individual credit assessment were deliberately left unclassified in the EBA's November 2025 factsheet, creating a "Schrödinger's compliance" state pending European Commission classification guidelines[52].

For all High-Risk systems, the Chief Architect must engineer compliance across Articles 9 through 15 and Article 18: establishing an ongoing Risk Management System integrated into enterprise risk procedures (Article 9), enforcing error-free and representative Data Governance across training, validation, and test sets (Article 10), compiling the 12 mandatory elements of Annex IV Technical Documentation retained for 10 years post-deployment via self-assessed conformity (Article 11 and Article 18), enabling automatic decision and input/output event logging (Article 12), providing deployer transparency (Article 13), and building genuinely operable Human Oversight capable of reviewing, stopping, or overriding any automated decision (Article 14)[52]. Note that for credit scoring models, retraining on a fundamentally different dataset, changing the target variable, or deploying the model in a new product context triggers re-assessment, whereas routine parameter retuning within defined thresholds typically does not[52].

Crucially, the Chief Architect must navigate a severe regulatory timing mismatch: while High-Risk Annex III obligations carry a primary enforcement milestone of August 2, 2026 (with select transitions for high-risk AI embedded in existing regulated products extending to August 2, 2027 under Article 111 and the European Commission's Digital Omnibus proposal), the harmonized European technical standard governing *how* to log AI decisions—CEN-CENELEC JTC 21's draft standard **ISO/IEC DIS 24970** under standardization request M/593/Amendment M/613—will not be finalized until Q4 2026 at the earliest[44]. Rather than waiting for final CEN-CENELEC publication, the bank's logging architecture must proactively implement **Clause 8.3.1 of ISO/IEC DIS 24970** alongside CISA's August 2026 Logging Reference Architecture, mandating full auditability of both ML model state information (weights, version, temperature, system prompt, and active adapters) and decision pathway data (the exact chain of MCP tool calls, retrieved RAG context chunks, and intermediate agent state transitions)[12].

DORA (Regulation 2022/2554) as the Operational Estate Layer

Whereas the EU AI Act governs the safety and fairness of the AI system itself, DORA—fully applicable as binding EU law since January 17, 2025—governs the operational resilience of the ICT estate in which the AI agent acts[16]. Non-compliance exposes a financial entity to fines reaching 2% of total worldwide annual turnover, up to €5 million for critical ICT third-party providers, and up to €1 million in personal liability for individual Management Board members[61]. DORA structures its obligations across five pillars: ICT risk management, incident management and reporting, digital operational resilience testing (including annual testing for all entities and threat-led penetration testing every three years for significant institutions), ICT third-party risk management, and information sharing[61].

Because an AI agent that modifies records or initiates payments is an "ICT-supported function," every production agent must be registered as an ICT asset with a documented risk assessment proportionate to its potential harm, scoped permissions rather than model promises, and named deployment accountability (Articles 5–16)[16]. Furthermore, DORA's Incident Management and Reporting pillar (Articles 17–23) mandates that any major ICT incident—such as an autonomous agent executing a consequential erroneous action—must be classified and reported to the competent authority (UKNF) on a strict timeline: an initial notification within **4 hours** of classification, followed by intermediate and final forensic reports[16]. Without the replayable run records and append-only database logs detailed in Section 3, reconstructing an agent's multi-step trajectory within a 4-hour regulatory window is impossible[16]. Finally, under DORA Articles 28–44 (ICT Third-Party Risk Management), every external LLM API provider, cloud hyperscaler, and agent platform vendor is an ICT third-party dependency that must be logged in the bank's Register of Information (reported annually to supervisors) with binding contractual clauses covering data use, audit rights, change notices, concentration risk, data residency, and exit strategies[16]. Deploying models and MCP services inside the bank's own Virtual Private Cloud converts the hardest third-party questions into internal architectural controls[14].

Polish National Supervision (UKNF): Rekomendacja W, Cloud Communiqué, and AML/CFT

In Poland, the Chief Architect must map the agentic stack directly onto three specific supervisory instruments enforced by the *Urząd Komisji Nadzoru Finansowego* (UKNF)[67]:

1. ***Rekomendacja W* (Model Risk Management)**: Issued under KNF Resolution 332/2015, *Rekomendacja W* explicitly encompasses machine learning, random forests, decision trees, and deep learning neural networks within its regulatory perimeter[69]. Under Recommendations 1, 4, 8, and 9, a Polish bank must integrate all utilized and planned models into its enterprise Model Risk Management (MRM) process across their entire lifecycle, regardless of materiality, data type, or whether the model is developed internally (*model wewnętrzny*) or supplied by an external vendor (*model zewnętrzny*)[69]. For every LLM or scoring agent deployed, the bank must update its formal Model Register (*Rejestr modeli*), maintain granular Model Logs (*Dzienniki modeli*) to support ongoing statistical monitoring and independent validation, and obtain comprehensive

technical documentation detailing key model elements, training data, assumptions, and inherent limitations even for third-party foundation models[69]. Applying the Principle of Proportionality (*Zasada proporcjonalności*) allows the Chief Architect to calibrate validation effort to model materiality—applying streamlined controls to non-material internal productivity assistants while enforcing rigorous statistical monitoring, acceptance criteria, and residual risk controls on material credit, market, operational, or liquidity models[69].

2. ***Komunikat Chmurowy UKNF* (Polish Cloud Computing Communiqué)**: Governs any AI workload processed in a public cloud or a hybrid cloud to the extent it utilizes public cloud infrastructure[68]. Before processing information in the cloud, the bank must classify the information (accounting for legally protected secrets such as Polish banking secrecy), perform continuous risk estimation grounded in **PN-ISO 27005** (or an equivalent standard) utilizing the iterative Deming cycle across general cloud threats, service-specific threats, and internal resource threats, and implement all risk mitigation controls prior to launch[68]. The bank must also maintain registers of cybersecurity personnel, network topology, and business continuity plans, collect and process cloud environment logs continuously, and notify UKNF no later than **30 days** after commencing cloud service usage[68]. Reassessment is mandatory whenever the bank processes a new category of information, adopts a new cloud AI service, significantly alters processing scale, or faces regulatory or contractual changes[72].
3. ***Stanowisko UKNF dot. Procesów AML/CFT***: Consulted with the General Inspector of Financial Information (GIIF) and read alongside GIIF Communiqués 35–38 and EBA Guidelines EBA/GL/2021/02[67]. In 2024, deficiencies in internal AML/CFT procedures accounted for 19.39% of all AML/CFT irregularities detected by KNF—more than double the rate recorded in 2021[67]. UKNF strictly penalizes both missing procedures and "facade procedures" (*fasadowość*) under Article 147 Point 7 of the Polish AML Act[67]. Consequently, introducing AI or agentic workflows into AML/CFT processes requires updating the bank's internal AML/CFT Procedure across the 11 statutory areas (plus additional risk-specific controls for high-risk products or outsourcing) and securing documented, timestamped approval from Senior Management—specifically the designated Management Board member under Article 7 and the AMLRO under Article 8, both of whom must have formally appointed deputies[67].

Operationalizing Runtime Assurance: NIST AI 600-1, ISO 42001, and AIUC-1

To bridge high-level legal mandates with daily engineering execution, the Chief Architect should adopt three complementary international standards as the internal evaluation harness[39]. The first is **NIST AI 600-1** (*Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, published July 26, 2024), which extends the voluntary NIST AI RMF 1.0 functions (Govern, Map, Measure, Manage) with 12 GAI-specific risk categories and 212 suggested actions across 49 subcategories, focusing on Governance, Content Provenance, Pre-deployment Testing, and Incident Disclosure[59]. The 12 risk categories—CBRN information,

Confabulation, Dangerous/violent/hateful content, Data privacy, Environmental impacts, Harmful bias or homogenization, Human-AI configuration, Information integrity, Information security, Intellectual property, Obscene/degrading/abusive content, and Value chain and component integration—provide an auditor-ready risk register vocabulary[40]. In banking, two NIST risks require immediate architectural prioritization: **Confabulation** (confidently stated false content regarding fees, rates, or account statuses, which regulators classify as deceptive practices) and **Human-AI Configuration** (mitigating automation bias, over-reliance, anthropomorphizing, and algorithmic aversion among human "checkers" reviewing agent outputs)[39].

Alongside NIST AI 600-1, the Chief Architect should utilize **ISO/IEC 42001** and **AIUC-1** as dual procurement and validation benchmarks[39]. While ISO/IEC 42001 specifies requirements for an overarching Artificial Intelligence Management System, **AIUC-1**—developed with Stanford, MIT, MITRE, and the Cloud Security Alliance—is the first technical standard focused specifically on how AI agents behave under pressure in production environments, mandating quarterly adversarial testing across data protection, operational boundaries, attack resistance, and error prevention[39]. Combining ISO/IEC 42001 governance with AIUC-1 quarterly red-teaming is essential to defend the bank against the escalating threat of AI-enabled financial crime: according to Sumsub's Identity Fraud Report 2025–2026, sophisticated multi-step fraud attacks combining synthetic identities, deepfakes, social engineering, and autonomous agentic attack chains rose 180% year-on-year to reach 28% of all identity fraud in 2025 (with deepfake fraud surging 1,100% and synthetic document fraud rising 311% in Q1 2025 alone), driving projected generative AI fraud losses toward $40 billion in the US by 2027[76].

6. Curated Architectural & Strategic Reading List: Books and Reports

To equip the Chief Architect, the Architecture Review Board, and lead engineering squads with practical, production-tested methodologies—replacing generic consulting slideware—the following books and regulatory/technical reports represent the definitive curriculum[57].

Resource Title & Author / Issuing Body	Category & Focus	Target Internal Audience	Core Practical Value for the Bank's AI Transformation
AI Engineering: Building Applications with Foundation Models — Chip Huyen (O'Reilly, 2025)[57]	Foundational Engineering Book	Chief Architect, Lead AI/Software Engineers	The premier systems-level framework for deciding between prompting, RAG, agentic workflows, and fine-tuning;

			covers evaluation benchmarks, dataset engineering, latency/cost trade-offs, and inference optimization (Polish translation also in progress)[57].
Designing Machine Learning Systems — Chip Huyen (O'Reilly, 2022)[57]	Production MLOps & Data Systems Book	MLOps Leads, Data Architects, Model Risk Teams	Solves the "60% model degradation in 6 months" problem[3]; provides rigorous engineering patterns for data distribution shifts, feature stores, continual evaluation, retraining pipelines, and enterprise ML platform design[57].
LLM Engineer's Handbook — Paul Iusztin & Maxime Labonne[57]	End-to-End LLMOps Lifecycle Book	Senior AI Engineers, Platform Engineering	Bridges the gap between "duct-taping GPT calls in a notebook" and running observable, maintainable production services; details data pipelines, fine-tuning, evaluation harnesses, and LLMOps monitoring[57].

Building Agentic AI Systems — Anjanava Biswas & Wrick Talukdar[77]	Multi-Agent Systems Book	Agentic Workflow Architects, Squad Leads	Dedicated engineering blueprint for designing autonomous agents capable of multi-step planning, external tool invocation, memory management, and bounded environment interaction[77].
Building LLMs for Production — Louis-François Bouchard & Louie Peters[77]	Production Scaling & Reliability Book	Infrastructure & AI Reliability Engineers	Focuses on the unglamorous engineering work of deploying, scaling, quantizing, and maintaining reliable LLM applications under live enterprise traffic constraints[77].
Build a Large Language Model (From Scratch) — Sebastian Raschka, PhD & ***Hands-On Large Language Models*** — Jay Alammar & Maarten Grootendorst[57]	Deep Model Mechanics & Intuition Books	Internal FinLLM Teams (e.g., Sovereign 1B–24B builders)	Essential for teams training or fine-tuning sovereign Polish financial models[17]; demystifies attention mechanisms, tokenizers, embeddings, and pre-training/post-training mechanics under the hood[57].
Prompt Engineering for LLMs — John	Context Engineering & Distributed Data	Application Developers, Core Database	Berryman & Ziegler treat prompt/context

Berryman & Albert Ziegler & ***Designing Data-Intensive Applications*** — Martin Kleppmann[77]	Books	Architects	construction as a rigorous software engineering discipline[77]; Kleppmann provides the foundational distributed systems theory (linearizability, idempotency, consensus) required for DORA-compliant agent databases[44].
AI Act: Implications for the EU Banking and Payments Sector — European Banking Authority (EBA, Nov 21, 2025)[60]	Regulatory Mapping Report	Chief Architect, CRO, Compliance & Legal	Authoritative EU supervisory baseline mapping Annex III High-Risk obligations (credit scoring, AML monitoring) directly against existing banking regulations (CRD/CRR, MiFID II, DORA, GDPR)[52].
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative AI Profile — NIST (July 2024)[59]	Operational Risk & Controls Report	AI Governance Hub, CISO, Internal Audit	Provides an auditor-ready risk register vocabulary (12 GAI risks including Confabulation and Human-AI Configuration) and 212 actionable controls mapped to Govern, Map, Measure, and Manage[40].

Rekomendacja W, ***Komunikat Chmurowy UKNF***, & ***Stanowisko UKNF dot. AML/CFT*** — UKNF[67]	Polish Supervisory Mandates	Management Board, Chief Architect, AMLRO	The non-negotiable local rulebook for Polish banks governing model registers, external model validation, cloud risk estimation (PN-ISO 27005), and senior management AML accountability[67].
Agentic AI in Financial Services: Choosing the Right Pattern for Multi-Agent Systems (AWS) & ***The State of MCP in Financial Services 2026*** (Stacklok)[14]	Technical Architecture Reports	Enterprise Architects, Cloud & Security Leads	Practical reference guides detailing Workflow, Swarm, and Loop multi-agent patterns, Large Singleton/Agent Washing anti-patterns, and VPC-isolated Model Context Protocol benchmarks across 100 financial services tech leaders[14].
Enterprise AI Architecture: A Layer-by-Layer Reference Guide (Kanerika, Sept 2026), ***AI Agents for Enterprise*** (SotaTek), & ***CISA Logging Reference Architecture*** (Aug 2026)[1]	Enterprise Reference Architecture Blueprints	Enterprise Architecture Board, CISO, Platform Leads	Defines the 6-to-8-layer Enterprise AI Reference Architecture, the 4-step vertical-slice rollout methodology, permission-aware retrieval, and federal-grade immutable agent logging[1].

Putting AI to Work: The Enterprise AI Playbook (BCG), ***Evident AI Index for Payments (Feb 2026)***, & ***Sumsub Identity Fraud Report 2025–2026***[34]	Executive Benchmarking & Threat Reports	Executive Committee, Fraud & Payments Heads	Quantifies banking peer governance maturity and details the 180% surge in multi-step agentic/deepfake fraud attacks that defensive banking architectures must counter[34].

7. Actionable 180-Day Enterprise Architecture Rollout Roadmap

To demonstrate immediate, concrete momentum to the Management Board—distinguishing an Enterprise Architecture-led strategy from failed consulting engagements—the Chief Architect should execute a disciplined, three-phase 180-day rollout built around the **Four-Step Vertical Slice & Reuse Methodology**[1].

Execution Phase & Horizon	Core Enterprise Architecture & Diagnostic Deliverables	Target Production Systems & Shared Services	Measurable Success Criteria & Risk Controls
Phase 1: Diagnostic Audit, Triage & Shared Control Plane (Days 1–60)	Execute **7-Day Top-3 Agent Diagnostic** & **8-Layer Governance Scorecard**; abolish isolated innovation labs; establish **Hub-and-Spoke** charter; deploy **Enterprise AI Gateway** and **VPC MCP Registry**[4].	Stand up **Four Shared Services** (Gateway/IAM, Permission-Aware Retrieval, LangGraph Orchestrator, WORM Audit Log)[1]; unify **Rekomendacja W** Model Register, **DORA** Register of Information, and **EU AI Act Art. 12 / ISO 24970** schemas[52].	100% of candidate backlog filtered via 6-point Use-Case Triage; legacy High-Risk credit/AML models audited; zero unowned shadow agents[8].
Phase 2: First	Launch two 90-day	**MVP 1**: Sovereign	Sub-100ms MCP

Vertical Slice & Stage 1–2 MVPs (Days 61–120)	parallel MVPs inside P&L Spokes progressing from **Stage 1 (Read)** to **Stage 2 (Draft / Maker-Checker)** over read-only **MCP Services** and synced caches[8].	Email/Complaint Triage Agent (Workflow pattern)[17]. **MVP 2**: Internal NL-to-SQL & Regulatory Knowledge Swarm grounded in a governed semantic layer[17].	context retrieval; 40%–70% inference cost reduction via semantic cache; UKNF 30-day cloud notification filed if applicable[15].
Phase 3: Reuse Test, Stage 3 Hardening & Scale (Days 121–180)	Execute the **Architectural Reuse Test** on a third workflow; harden distributed SQL storage for **Stage 3 (Write Within Limits)**; institutionalize **DORA Kill-Switch Drills** and quarterly **AIUC-1 / NIST AI 600-1** red-teaming[1].	Promote reusable MCP services (Customer Context, Ledger Cache Read, Policy KB) to central enterprise catalog to scale toward **30+ production agents**[7].	Verified 0 post-stop actions in Kill-Switch drill; <4-hour DORA incident reconstruction; second/third workflows ship 50%+ faster by inheriting Phase 1 shared services[12].

Phase 1: Diagnostic Audit, Triage, and Shared Control Plane (Days 1–60)

During the first 60 days, the Chief Architect must execute the **7-Day Top-3 Privileged Agents Diagnostic** and score the institution against the **8-Layer Enterprise Governance Scorecard** to establish an empirical baseline[55]. Standalone innovation sandboxes that lack P&L sponsorship are dissolved in favor of the Federated Hub-and-Spoke charter[4]. Rather than attempting a multi-year bank-wide data consolidation, the Central Architecture Hub stands up the **Four Core Shared Services** required for the first vertical slice: (1) the Enterprise AI Gateway integrated with corporate OIDC/SAML identity providers, Redis 8.0 vector semantic caching, portfolio model routing, and semantic prompt guards; (2) the VPC-isolated MCP Registry enforcing the seven financial MCP governance rules (default read-only access, zero shared tokens, tokenized PII, and semantic layer grounding); (3) the stateful LangGraph orchestration runtime; and (4) the unified WORM audit log[1]. Concurrently, the Hub unifies the bank's existing *Rekomendacja W* Model Register (*Rejestr modeli*) and DORA Register of Information to incorporate EU AI Act Annex IV technical documentation and Article 12 / ISO/IEC DIS 24970 Clause 8.3.1 logging schemas[52].

Phase 2: First Vertical Slice & Stage 1–2 Augmented MVPs (Days 61–120)

In the second 60-day window, the bank executes its six-point Use-Case Triage to reject speculative slide-deck ideas, measures baseline human hours and error rates, and launches two parallel 90-day production MVPs tested on real users against written pass/fail hypotheses[8]. Both MVPs follow the **Five-Layer Systems-of-Record Integration Blueprint**: the agents hold zero database credentials, read exclusively from synced caches or warehouses via MCP services so core banking systems are never overloaded, and progress strictly from **Stage 1 (Read)** into **Stage 2 (Draft / Maker-Checker)**[12]. Drawing from the proven production playbooks of PKO Bank Polski, mBank, and JPMorgan Chase, the first MVP deploys an Autonomous Triage and Correspondence Agent utilizing a sequential Workflow Pattern in LangGraph to ingest customer messages, extract document context via OCR and GenAI, query read-only core banking MCP servers for account history, classify urgency, and pause at a checkpoint for one-click advisor approval[17]. The second MVP deploys an Internal "Talk to Your Data" and Regulatory Analyst Assistant utilizing a Swarm Pattern connected via MCP to a governed finance semantic layer, enabling risk, compliance, and corporate analysts to query database tables and internal policy documents with permission-aware retrieval and full citation lineage[1]. During this phase, the architecture team also benchmarks hybrid unit economics—comparing public cloud LLM APIs (governed under the UKNF Cloud Communiqué 30-day notification and PN-ISO 27005 risk estimation regime) against VPC-hosted sovereign Polish financial models (1B to 24B parameters), Small Language Models (SLMs), and on-premise speech-to-text pipelines[11].

Phase 3: Architectural Reuse Test, Stage 3 Hardening, and Horizontal Scale (Days 121–180)

In the final 60-day phase, the Chief Architect conducts the mandatory **Architectural Reuse Test**: onboarding a third banking workflow onto the identity model, AI Gateway, MCP servers, and audit log built in Phases 1 and 2 to verify that horizontal expansion ships significantly faster without custom re-architecture[1]. Before permitting any mature workflow to graduate from Stage 2 (Draft) to **Stage 3 (Write Within Deterministic Limits)**, the Chief Architect verifies the five pre-deployment DORA database controls at the storage layer: append-only tamper-evident audit logs, per-agent cryptographic identity attribution on every write, strong linearizable read consistency across nodes, storage-layer idempotency keys, and automated compensating transactions[12]. The bank then conducts and times its first live **DORA Kill-Switch Drill**—proving zero post-stop actions, generating a complete write rollback manifest, and verifying dual-control restart approval—while confirming that replayable run logs allow forensic teams to reconstruct any major agent incident well within DORA's mandatory 4-hour regulatory reporting window[16]. Concurrently, the security team initiates quarterly adversarial red-teaming aligned with AIUC-1 and NIST AI 600-1 to test defenses against confabulation, prompt injection, and human automation bias[39]. With the shared enterprise foundation proven and audited, the Central Hub exposes its MCP services as a governed internal catalog, enabling the bank to

scale systematically to 30 or more production agents across business units[1].

Works cited

1. Enterprise AI Architecture: 6 Layers and How to Build It - SotaTek, https://www.sotatek.com/blogs/ai-and-machine-learning/enterprise-ai-architecture/
2. Thought Leadership Archives - Navirum, https://navirum.com/category/thought-leadership/
3. AI Strategy & Roadmap Assessment: How Enterprises Avoid 88% AI, https://www.improving.com/thoughts/ai-strategy-and-roadmap-assessment/
4. AI scaling is not failing in financial institutions. It's being blocked., https://www.projectivegroup.com/ai-scaling-is-not-failing-in-financial-institutions-its-being-blocked/
5. Why AI Projects Fail? 20 Root Causes and the Path to Success, https://softteco.com/blog/why-ai-projects-fail
6. Generative AI in Banking: Push Past Proof of Concept Fatigue, https://www.cognizant.com/us/en/insights/insights-blog/how-to-operationalize-generative-ai-in-banking
7. The Enterprise AI Reference Architecture for Modern Organizations, https://medium.datadriveninvestor.com/the-complete-enterprise-ai-architecture-blueprint-for-2026-da44ee6acaaa
8. AI Consulting for Financial Services in the UK: What to Expect, https://innovify.com/insights/ai-consulting-financial-services-uk
9. Why most enterprise AI projects stall before they scale - IBM, https://www.ibm.com/think/insights/why-most-enterprise-ai-projects-stall-before-scale
10. Systems of Record vs Systems of Action: How AI Is Changing, https://nexaitech.com/systems-of-record-vs-systems-of-action/
11. Enterprise AI Architecture: Layers, Patterns & Decisions - Kanerika, https://kanerika.com/blogs/enterprise-ai-architecture/
12. Enterprise AI Architecture for ERP and CRM Agents | Ovidius, https://www.ovidius.ai/blog/enterprise-ai-architecture-how-agents-connect-to-your-erp-crm-and-data
13. Kong vs LiteLLM: Architecture, Pricing, and Trade-Offs - TrueFoundry, https://www.truefoundry.com/blog/kong-vs-litellm
14. MCP Platform for Financial Services - Stacklok, https://stacklok.com/industry/financial-services/
15. How AI Gateways Enable Scalable AI Connectivity - Kong Inc., https://konghq.com/blog/enterprise/ai-gateways-for-scalable-ai-connectivity
16. DORA Compliance for AI Agents - moring.ai, https://www.moring.ai/blogs/dora-compliance-ai-agents/
17. PKO Bank Polski ma pierwszego agenta AI i szybciej odpowie na, https://www.pkobp.pl/media/aktualnosci/informacje-o-banku/pko-bank-polski-ma-pierwszego-agenta-ai-i-szybciej-odpowie-na-maile-klientow

18. GenAI to nie eksperyment. To świadoma, strategiczna decyzja banku, https://itwiz.pl/genai-to-nie-eksperyment-to-swiadoma-strategiczna-decyzja-banku/
19. MCP: Secure AI Agents for Financial Systems - Arcade.dev, https://www.arcade.dev/blog/enterprise-mcp-guide-for-fintech-financial-institutions/
20. AI and Model Context Protocol in Banking: Transforming Financial, https://medium.com/@balarampanda.ai/ai-and-model-context-protocol-in-banking-transforming-financial-services-through-intelligent-agent-71ae00c1bfea
21. An Architectural Blueprint for Agentic AI in Banking - Medium, https://medium.com/emergent-intelligence/moving-beyond-chatbots-a-blueprint-for-autonomous-ai-in-banking-c219bb38341d
22. What is Model Context Protocol and what does it mean for lending?, https://www.loanpro.io/blog/what-is-model-context-protocol/
23. Agentic AI in Financial Services: Choosing the Right Pattern for Multi, https://aws.amazon.com/blogs/industries/agentic-ai-in-financial-services-choosing-the-right-pattern-for-multi-agent-systems/
24. Top AI Development Companies for US Financial Institutions - Adastra, https://adastracorp.com/articles/top-ai-development-companies-for-us-banks-and-financial-institutions-2026-guide/
25. Designing an Enterprise Agentic AI Architecture for ... - Algomine, https://algomine.ai/stories/enterprise-agentic-ai-architecture/
26. mBank i PKO BP w gronie europejskich banków biorących udział w, https://bank.pl/mbank-i-pko-bp-w-gronie-europejskich-bankow-bioracych-udzial-w-eksperymentalnych-zakupach-z-agentem-ai-od-visa/
27. Agent AI zrealizował pierwszą w Polsce transakcję przy ... - Cashless, https://www.cashless.pl/18971-agent-ai-zrealizowal-pierwsza-w-polsce-transakcje-przy-pomocy-rozwiazania-mastercarda
28. Aktualne wyzwania prawne związane z zastosowaniem AI ... - PABWIB, https://pabwib.pl/produkt/aktualne-wyzwania-prawne-zwiazane-z-zastosowaniem-ai-w-polskim-sektorze-bankowym/
29. ING uruchamia pilotaż Asystenta AI opartego na GenAI w ING, https://media.ing.pl/informacje-prasowe/926/pr/862367/ing-uruchamia-pilotaz-asystenta-ai-opartego-na-genai-w-ing-business
30. What Is Model Context Protocol (MCP) for Finance? - Keboola, https://www.keboola.com/glossary/model-context-protocol-for-finance
31. How Model Context Protocol Transforms Financial Analysis - Daloopa, https://daloopa.com/blog/analyst-best-practices/model-context-protocol-strategy-game-changer-for-financial-analysis
32. PKO BP uruchomił pierwszego agenta AI, który obsłuży klientów, https://inwestycje.pl/biznes/pko-bp-uruchomil-pierwszego-agenta-ai-ktory-obsluzy-klientow-nawet-70-szybciej/
33. GenAI w mBanku: wsparcie dla pracowników i jeszcze lepsza jakość, https://pl.media.mbank.pl/406922-genai-w-mbanku-wsparcie-dla-pracownikow-i-jeszcze-lepsza-jakosc-obslugi

34. From PoC to Production: Scaling Enterprise AI Without Failing, https://aiconference.london/news/from-poc-to-production-scaling-enterprise-ai-without-failing-august-2026-20260803-12
35. How System One Models Like Jev Change Enterprise AI Architecture, https://www.kai-waehner.de/blog/2026/09/28/how-system-one-models-like-jev-change-enterprise-ai-architecture/
36. Announcing Kong AI Gateway 3.8 With Semantic Caching and, https://konghq.com/blog/product-releases/ai-gateway-3-8
37. Human-in-the-loop AI agents: governance design patterns - Dataiku, https://www.dataiku.com/blog/human-in-the-loop-ai-agents
38. Planner-Executor vs. Graph-Based Orchestration (LangGraph) in, https://www.c-sharpcorner.com/article/planner-executor-vs-graph-based-orchestration-langgraph-in-banking
39. AI Agent Compliance for Financial Services (2026) - Fin AI, https://fin.ai/learn/evaluate-ai-agent-compliance-financial-services
40. Generative AI Profile: A Clear Guide to the 12 NIST AI Risks, https://governancedocs.com/nist-ai-rmf-generative-ai-profile/
41. LangGraph Human in the Loop: Ultimate AI Workflow Guide 2026, https://www.skakarh.com/blog/langgraph-human-in-the-loop
42. Agentic AI in Finance and Accounting: The 2026 CFO Guide, https://assistents.ai/blogs/agentic-ai-in-finance-and-accounting
43. AI Use Cases in Banking: Agentic AI for Bank and Credit Union, https://www.botminds.ai/guides/banking
44. DORA Database Requirements for AI Agents - Cockroach Labs, https://www.cockroachlabs.com/blog/dora-database-requirements-ai-agents/
45. Human in the loop tutorial - AI agents - IBM, https://www.ibm.com/think/tutorials/human-in-the-loop-ai-agent-langraph-watsonx-ai
46. Human-in-the-Loop AI: Time-Travel Workflows with LangGraph, https://christianmendieta.ca/human-in-the-loop-ai-time-travel-workflows-with-langgraph/
47. LangGraph for Complex Enterprise Workflows with AI Agents, https://www.auxiliobits.com/blog/how-langgraph-enables-complex-enterprise-workflows-with-ai-agents/
48. AI Gateway Benchmark: Kong AI Gateway, Portkey, and LiteLLM, https://konghq.com/blog/engineering/ai-gateway-benchmark-kong-ai-gateway-portkey-litellm
49. Kong AI Gateway vs LiteLLM, https://konghq.com/blog/enterprise/kong-ai-gateway-vs-litellm
50. Redislabs-Solution-Architects/kong-ai-gateway-demo - GitHub, https://github.com/Redislabs-Solution-Architects/kong-ai-gateway-demo
51. MCP: The next frontier for financial markets - LSEG, https://www.lseg.com/en/insights/mcp-the-next-frontier-for-financial-markets
52. EU AI Act for Financial Services: What Banks & Insurers Must Do, https://alicelabs.ai/en/insights/eu-ai-act-for-financial-services

53. AI Core Banking Analyst | Cory Bankson | FluxForce, https://www.fluxforce.ai/ai-agents/ai-core-banking-analyst
54. AI Open Banking Analyst | Piers Openfield - FluxForce AI, https://www.fluxforce.ai/ai-agents/ai-open-banking-analyst
55. Your enterprise isn't ready for enterprise AI - CIO, https://www.cio.com/article/4209896/your-enterprise-isnt-ready-for-enterprise-ai.html
56. The hidden cost of poor AI Development | 247 Labs, https://247labs.com/the-hidden-costs-of-rushed-ai/
57. I Read 20+ Books on AI Engineering and LLMs — Here Are My Top, https://medium.com/javarevisited/i-read-20-books-on-ai-engineering-and-llms-here-are-my-top-5-recommendations-for-2026-70a3d4976fea
58. NIST AI 600-1: The Generative AI Profile Explained, https://trussed.ai/resources/nist-ai-600-1-the-generative-ai-profile-explained
59. NIST AI 600-1 Generative AI Profile | OneClickComply, https://oneclickcomply.com/standards/nist-ai-600-1
60. The EU AI Act's Logging Requirements Are Clear. - Medium, https://medium.com/@veritaschain/the-eu-ai-acts-logging-requirements-are-clear-27c5a600ef30
61. Digital Operational Resilience Act: A Complete Guide - Zenity, https://zenity.io/academy/digital-operational-resilience-act
62. AI Act: implications for the EU banking and payments sector, https://www.eba.europa.eu/sites/default/files/2025-11/d8b999ce-a1d9-4964-9606-971bbc2aaf89/AI%20Act%20implications%20for%20the%20EU%20banking%20sector.pdf
63. EBA factsheet: AI Act implications for the EU banking and, https://www.bankingnewsai.com/ai-regulation/documents/eba-ai-act-factsheet-2025
64. Is Your AI System High-Risk? The EU AI Act Classification Guide, https://www.euaiact.com/blog/eu-ai-act-high-risk-classification
65. EU AI Act For High Risk AI in a Nutshell - LCFI, https://www.lcfi.ac.uk/news-events/blog/post/eu-ai-act-for-high-risk-ai-in-a-nutshell
66. Bridging the AI Governance Gap in Financial Institutions - Bird & Bird, https://www.twobirds.com/en/insights/2026/bridging-the-ai-governance-gap-in-financial-institutions
67. Stanowisko UKNF dotyczące Procedury AML/CFT - Legal Geek, https://legalgeek.pl/blog/aml-stanowisko-uknf-procedura-aml-cft/
68. Komunikat Chmurowy KNF – nowe obowiązki dla sektora ... - EY, https://www.ey.com/pl_pl/insights/biuletyn-ryzyka/komunikat-chmurowy-knf-nowe-obowiazki-dla-sektora
69. Komisja Nadzoru Finansowego Rekomendacja W, https://www.knf.gov.pl/knf/pl/komponenty/img/knf_137749_Rekomendacja_W_42219.pdf
70. AI Governance dla rad nadzorczych banków | Rama 2026,

https://thinking.inc/pl/boss-articles/uslugi-finansowe-governance/
71. Zarządza Zarządzanie ryzykiem modeli - Warszawa - KNF, https://www.knf.gov.pl/knf/pl/komponenty/img/publikacja_zarzadzanie_ryzykiem_modeli_92496.pdf
72. Cloud computing - komunikat chmurowy KNF - O co chodzi?, https://rpms.pl/komunikat-chmurowy-knf-o-co-chodzi-z-przetwarzaniem-informacji-w-chmurze-obliczeniowej/
73. Chmura obliczeniowa w sektorze bankowym na świecie, w Europie, https://www.zbp.pl/zbp/media/zbp/aktualnosci/wydarzenia/kwiecien%202020/cloud/raport-cloud.pdf
74. NIST AI RMF Generative AI Profile (NIST AI 600-1) — The 12 Risks, https://docs.modulos.ai/frameworks/nist-ai-rmf/generative-ai-profile
75. Artificial Intelligence Risk Management Framework - NIST, https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence
76. AI readiness in financial crime: Deployment, understanding and, https://thepaymentsassociation.org/article/ai-readiness-in-financial-crime-deployment-understanding-and-operational-capability/
77. I Read 20+ Books on AI and LLM Engineering: Here Are My Top 10, https://dev.to/somadevtoo/i-read-20-books-on-ai-and-llm-engineering-here-are-my-top-10-recommendations-3ab
78. Books - Chip Huyen, https://huyenchip.com/books/
79. Designing Machine Learning Systems: An Iterative Process for, https://www.goodreads.com/book/show/60715378
80. Stop Watching AI Tutorials. Read These 6 Books to Become a Real, https://www.youtube.com/watch?v=XKa-1vTLLsk